

AUDITORÍA Y REPORTE DE INCIDENTE DE CIBERSEGURIDAD

Análisis bajo el Marco NIST CSF: Ataque de Denegación de Servicio
(DoS)

Autor: Ing. Mauro Alejandro Guadarrama García

Ingeniero en Sistemas Computacionales

Proyecto de Portafolio

Certificado Profesional de Ciberseguridad de Google

Junio 2026

1. Introducción al Problema

El presente documento detalla la auditoría técnica de un incidente de ciberseguridad que afectó a la infraestructura de red de una empresa proveedora de servicios multimedia y de marketing digital. La organización sufrió un ataque de **Denegación de Servicio (DoS)** que comprometió y paralizó la red interna durante aproximadamente dos horas.

La interrupción fue causada por un actor malicioso que aprovechó un cortafuegos (firewall) sin configurar para enviar una avalancha masiva de pings ICMP (paquetes de solicitud de eco). Esta inundación de tráfico saturó por completo el ancho de banda y los recursos de procesamiento, impidiendo que el tráfico normal de la empresa pudiera acceder a los recursos de red críticos.

2. Solución y Puntos Clave de la Auditoría (NIST CSF)

Para abordar el incidente de forma estructurada, la auditoría y la respuesta se alinearon con las cinco funciones principales del **Marco de Ciberseguridad del Instituto Nacional de Estándares y Tecnología (NIST CSF)**. A continuación, se detallan las medidas implementadas:

I. Identificar (Identify)

Se identificó que el ataque fue un DoS volumétrico basado en una inundación ICMP (ICMP flood). La vulnerabilidad auditada fue la ausencia de reglas de filtrado de tráfico en el cortafuegos principal. Los sistemas afectados incluyeron la totalidad de la red interna y los servicios críticos de diseño y marketing alojados en ella.

II. Proteger (Protect)

Para proteger la red de futuros ataques similares, se actualizaron de inmediato los controles de seguridad perimetral. Se implementó una nueva regla en el cortafuegos para aplicar un límite de tasa (rate limiting) a los paquetes ICMP entrantes. Además, se habilitó la verificación de la dirección IP de origen en el cortafuegos para bloquear intentos de suplantación de identidad (IP spoofing).

III. Detectar (Detect)

Se subsanó la falta de visibilidad en la red mediante la instalación de un software de supervisión de red continuo, capaz de alertar sobre patrones de tráfico anómalos o picos inusuales. Complementariamente, se desplegó un Sistema de Detección y Prevención de Intrusos (IDS/IPS) para inspeccionar y filtrar el tráfico basándose en características sospechosas.

IV. Responder (Respond)

El equipo de respuesta a incidentes logró contener la amenaza bloqueando proactivamente los paquetes ICMP entrantes en el nivel del cortafuegos. Como medida táctica, se desconectaron los servicios no críticos para liberar recursos de la red, mientras se analizaban los registros (logs) para rastrear la naturaleza del ataque y neutralizar la entrada de tráfico hostil.

V. Recuperar (Recover)

Una vez mitigado el ataque, el plan de recuperación consistió en un restablecimiento escalonado. Se priorizó la reactivación de los servicios de red críticos vitales para el negocio. Tras verificar la integridad de los datos y confirmar la estabilidad del tráfico normal mediante las nuevas herramientas de monitoreo, se restauraron progresivamente los servicios no críticos hasta lograr el 100% de la operatividad.

3. Conclusión

La aplicación del marco NIST CSF permitió no solo mitigar el ataque de Denegación de Servicio de manera efectiva, sino también transformar un evento crítico en una oportunidad para endurecer la infraestructura. La red ahora cuenta con un modelo de seguridad proactivo, con controles de prevención (rate limiting e IP spoofing protection) y capacidades de detección en tiempo real (IDS/IPS), garantizando la continuidad del negocio ante amenazas volumétricas futuras.